SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1433**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**
2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.**(20 Mark).**
3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure.**(10 Marks)**

Code of Conduct:

I **Avinash M / 192521196** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: ___Avinash M _____

Submitted by: Name: **Avinash M**
Reg. No: **192521196**

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weight (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1: Nmap Network Scan Analysis (20 Marks)

1.1 Introduction

Nmap (Network Mapper) is a free and open-source tool which is used in the scanning phase of ethical hacking. It sends packets to a target machine and studies the replies to find out which ports are open, which services are running on those ports, and which operating system the machine is using. In this question the security analyst has scanned the host 192.168.1.10 and the report shows that port 80 (HTTP), port 22 (SSH) and port 3306 (MySQL) are open. The operating system and the service versions are also shown in the report.

Every open port is a way into the system. A service that is listening on a port is a program, and programs can have bugs, wrong settings or weak passwords. So an Nmap report is important for both sides. The ethical hacker uses it to find the weak points and fix them, and a real attacker uses the same information to plan an attack. In this answer I analyse the report, explain the risks of each service, discuss how an attacker may exploit them, and suggest the security measures.

1.2 Analysis of the Report

The report of the scan is similar to the following sample output. The version numbers are only an example of an old server which is not updated.

```
Nmap scan report for 192.168.1.10
Host is up (0.0021s latency).
PORT      STATE  SERVICE   VERSION
22/tcp    open   ssh       OpenSSH 7.4 (protocol 2.0)
80/tcp    open   http      Apache httpd 2.4.29 (Ubuntu)
3306/tcp  open   mysql     MySQL 5.7.x
OS details: Linux 4.x (Ubuntu 18.04)
```

From this report the following points can be understood. Port 22 is used for remote login using SSH, port 80 is used by the web server and port 3306 is used by the MySQL database. All three are in the open state, which means that the firewall (if any) allows connections to them from the place where the scan was done.

Port	Service	What it means for security
22	SSH (OpenSSH)	Remote administration is possible. If the password is weak or the software is old, an attacker can get control of the server.

Port	Service	What it means for security
80	HTTP (Apache)	The website runs here. Data is not encrypted and the web application may have vulnerabilities.
3306	MySQL	The database is reachable over the network. It should normally be available only to the web server.
OS / versions	Linux, service banners	Attackers can search for known vulnerabilities of exactly these versions.

Three important things are seen in this report. First, the web server, the SSH service and the database are all on the same machine, so if one service is broken the others are also in danger. Second, the version information is visible. Third, the database port is open to the network, which is not a good practice at all.

1.3 Security Risks of the Identified Services

HTTP (Port 80)

HTTP sends data in plain text. If a user logs in through a page that uses HTTP, the username, password and session cookie can be captured by anyone who is on the same network, for example by a man-in-the-middle attack. The web application which runs on the server is also the most attacked part of any system. Common problems are SQL injection, cross-site scripting (XSS), broken authentication, insecure file upload and wrong server configuration, which are listed in the OWASP Top 10. If the Apache version is old, it may also have known vulnerabilities which allow information leakage, denial of service or even remote code execution. Default pages, directory listing and backup files left on the server can also give useful information to the attacker.

SSH (Port 22)

SSH gives a remote command line to the server, so whoever gets in through SSH can control the whole system. The protocol is secure, but the way it is configured is often weak. If password login is allowed, the attacker can try many usernames and passwords (brute force or password spraying), and users who keep simple or reused passwords are easily caught. If root login is allowed, a single correct guess gives full control. An old OpenSSH version may support weak algorithms or have known bugs. Also, if there is no logging or lockout, the failed attempts will not be noticed by anyone.

MySQL (Port 3306)

The database stores the most valuable data of the organisation, such as customer details, passwords and business records. A database should never be open to everyone. When port 3306 is reachable, anyone can try to log in directly and skip the website completely. Many servers have weak settings like an empty root password, default accounts, or application users who have too many privileges. Old MySQL versions can also have vulnerabilities. If the connection is not encrypted, the data and the login details can be read on the network.

Operating System and Version Disclosure

Showing the OS and the exact versions is a risk in itself. With the version number an attacker can search the CVE and National Vulnerability Database (NVD) websites and quickly find which weaknesses will work. This saves the time of the attacker and makes the attack more accurate. An old kernel may also allow a normal user to become an administrator after the first entry into the system.

1.4 How an Attacker Could Exploit These Services

A real attacker normally follows steps such as reconnaissance, scanning, gaining access, maintaining access and covering tracks. The Nmap report already gives the first two steps, so the attacker can directly go to find a weak service. The possible ways are explained below at a general level.

Through the web server: the attacker studies the website and looks for input forms and login pages. If the input is not checked properly, SQL injection may allow the attacker to read or change the database or to bypass the login. An insecure upload option may allow a malicious script to be uploaded, and then the attacker can run commands on the server with the rights of the web server user.

Through SSH: automated tools can try thousands of common passwords or passwords leaked from other websites. If even one user has a weak password, the attacker gets a shell on the machine. After this the attacker can install a backdoor, create a new user and try to become the root user.

Through MySQL: if the database accepts remote connections, the attacker can try to log in with default or guessed passwords. After login he can read, change or delete the data. If the account has high privileges, the database can sometimes be misused to read or write files on the server, which may lead to command execution.

Through known vulnerabilities: because the versions are known, the attacker can use public exploit code for those versions. This needs very little skill and is one of the main reasons for real-world attacks on servers which are not patched.

The three services are on the same host, so the attacker can combine them. For example, a flaw in the website can reveal the database password from a configuration file. The data in the database may contain user passwords, which may be reused for SSH. Once the attacker controls the server, he can move to other computers in the 192.168.1.x network (lateral movement) and may steal data, install ransomware, deface the website or stop the service. These actions affect the confidentiality, integrity and availability of the system, which are the three goals of information security.

Effect on the CIA triad

If the attack is successful, all three goals of security are affected. Confidentiality is lost when customer records, passwords and business data are read or copied from the database. Integrity is lost when the attacker changes the data, the website pages or the user accounts, or places a backdoor in the system. Availability is lost when the server is stopped by a denial of service attack, when the files are encrypted by ransomware or when the database is deleted.

1.5 Recommended Security Measures

The main idea of protection is defence in depth, which means using many layers of security so that if one layer fails, the others still protect the system. The first step is to reduce the attack surface by closing every port and service that is not needed.

General measures

- Use a firewall (for example iptables, UFW or a network firewall) with a default deny rule, and allow only the ports that are really required.
- Keep the database in a private network segment or VLAN so that only the web server can connect to it.
- Update the operating system, Apache, OpenSSH and MySQL regularly, and keep a list of all software versions.
- Hide the version information. For example, in Apache the settings ServerTokens Prod and ServerSignature Off can be used.
- Use an intrusion detection or prevention system such as Snort or Suricata, and a tool like Fail2ban to block repeated failed logins.

- Collect logs in a central place or SIEM and create alerts for port scans, failed logins and unusual database activity.
- Do vulnerability scans and penetration tests regularly and fix the findings according to their severity.

Service-wise measures

Service	Protection
HTTP (80)	Force HTTPS with a valid TLS certificate (TLS 1.2 or above) and enable HSTS. Use a Web Application Firewall. Validate all user input and use parameterised queries. Disable directory listing, remove default and backup files, add security headers, and run the web server with a low-privilege account.
SSH (22)	Disable password login and use key-based authentication. Set PermitRootLogin to no. Use multi-factor authentication and allow SSH only from trusted IP addresses or through a VPN. Use the latest OpenSSH with strong ciphers and limit the number of login attempts.
MySQL (3306)	Bind MySQL to localhost or the private interface and block port 3306 in the firewall. Remove anonymous users and the test database. Use strong unique passwords and do not allow remote root login. Give each application user only the privileges it needs and enable TLS for connections.
Operating system	Apply security patches, follow a hardening guide such as CIS benchmark, enable SELinux or AppArmor, remove unused software and enforce the principle of least privilege.

If the work has to be done in order of importance, the first thing to do is to close the MySQL port to the outside network, because it is the most serious problem. After that, HTTPS should be enforced and the web server should be patched, then SSH should be changed to key-based login, and finally the version information should be hidden.

Risk priority

Priority	Finding	Risk	Action
1	MySQL open to the network	Critical	Restrict to localhost or the web server at once and check all accounts
2	HTTP without encryption and old Apache	High	Enforce HTTPS, update Apache, test the web application
3	SSH with password login	High	Use keys, MFA and IP restriction

Priority	Finding	Risk	Action
4	OS and version disclosure	Medium	Patch the system and hide banners

After the measures are applied, the scan should be repeated with Nmap to confirm that the unwanted ports are closed and that the version information is no longer visible. This retesting step is part of the normal ethical hacking cycle and makes sure that the problems are really solved.

1.6 Conclusion

The Nmap report shows that the target has a web server, SSH and a database open on the network, and also reveals the operating system and the versions. Each service has its own risks and together they give an attacker many ways to enter the system. By closing unnecessary ports, using encryption, strong authentication, regular patching, network segmentation and monitoring, the organisation can reduce the risk and protect the confidentiality, integrity and availability of its system.

Question 2: GoPhish Phishing Campaign Analysis (20 Marks)

2.1 Introduction

Social engineering is an attack in which the attacker tricks a person instead of breaking a computer system. Phishing is the most common type of it. GoPhish is an open-source phishing simulation tool. With the permission of the management, it is used to send fake phishing emails to the employees of an organisation and to record what each person does, for example whether the email was opened, the link was clicked, the data was submitted or the attachment was downloaded. The result helps the organisation to know how strong its human security is.

Phishing has many forms. Email phishing is sent to a large number of users, spear phishing is aimed at one person or a small group with personal details, whaling targets senior managers, vishing uses phone calls and smishing uses text messages. In all of these forms the attacker tries to make the victim click a link, give a password, or open a file.

In this question a phishing awareness campaign was done for the employees of ABC Technologies Pvt. Ltd. The report says that 40% of the employees clicked the phishing link, 20% entered their login credentials and several users downloaded a malicious attachment. The following sections analyse these results.

2.2 Analysis of the Report

To understand the numbers, let us assume that 200 employees received the email. Then the results are as follows.

Stage	Employees	Percentage	Meaning
Email received	200	100%	The email reached the inbox
Clicked the link	80	40%	They trusted a fake link
Entered credentials	40	20%	Half of the people who clicked gave their password
Downloaded attachment	Several	-	Unsafe file handling

The click rate of 40% is high. In many awareness programmes the first click rate is between 10% and 30%, and a mature organisation tries to keep it below 10%. So the awareness level of the employees is low. The most serious result is the 20% who entered their username and password. It means that half of the people who clicked the link also gave their credentials. In a real attack the attacker would get these accounts and could read emails, open files and enter

the company systems. The downloaded attachment is also dangerous because a real malicious file can install ransomware, spyware or a remote access tool. Since all three things happened (clicking, entering the password and downloading), the problem is not by one person only. It is a weakness of the whole organisation in training, technology and procedures.

Phishing works because it uses the normal behaviour of people. The attacker usually creates a message that looks real, with the logo and the language of a known company or of the management, and adds a reason to act quickly. The fake login page also looks like the real one, so a person who is in a hurry does not notice the difference. A GoPhish campaign copies exactly this method in a safe way, so the organisation gets the real picture of its weaknesses without any loss.

2.3 Security Weaknesses Shown by the Employees

The campaign showed the following weaknesses.

- Lack of awareness. Employees did not notice the signs of phishing, such as a strange sender address, a general greeting, spelling mistakes and an unknown link.
- Reacting to urgency and authority. Phishing mails usually say that the account will be blocked or that the manager needs something quickly, and the employees act without thinking.
- Not checking the link. Many users did not move the mouse over the link to see the real address, or did not check the website name and certificate.
- Giving the password on a page opened from an email. The correct way is to open the official website by typing the address.
- Opening attachments without checking the sender or scanning the file.
- Not knowing how to report. If employees are afraid to report or do not know how, the security team cannot act in time.
- Weak password habits such as using the same password in many places, so one stolen password affects many accounts.

There are also weaknesses in technical controls and in the organisation. The phishing mail reached the inbox, so the email filter was not strong enough. If a password alone is enough to log in, then multi-factor authentication is not used. The user could download the file, so the endpoint protection is also weak. Finally, there may be no clear policy about suspicious emails and no quick detection of the click and password submission events.

2.4 User Awareness Programs

Technology cannot fully stop social engineering because the attacker targets the human. So a continuous awareness programme is necessary. The following are recommended.

- Compulsory security awareness training for all new employees and a refresher course every six months, covering phishing, vishing, smishing, pretexting, baiting and tailgating.
- Teaching practical skills like checking the sender address, hovering over links, looking at the domain name, and confirming unusual requests by phone or in person.
- Regular phishing simulations using GoPhish every quarter with different themes such as fake invoices, courier messages, password expiry and HR notices.
- Immediate short training for the employees who clicked the link, which explains the signs they missed. This is more useful than punishment.
- Special training for high-risk groups like finance, HR, administrators, the help desk and top management.
- A Report Phishing button in the email client, and appreciation for the employees who report suspicious emails.
- Posters, newsletters, short videos and quizzes to keep the awareness fresh, and teaching about password managers and strong passphrases.

2.5 Email Security Controls

Several technical controls should be used so that fewer phishing emails reach the users and the damage is small even if somebody clicks.

- SPF, DKIM and DMARC should be set up to stop other people from sending emails that look like they come from the organisation's domain. DMARC should be moved slowly from monitoring to quarantine or reject.
- A secure email gateway or anti-phishing filter should scan the incoming mail for spam, bad links and impersonation.
- Attachments should be scanned and opened in a sandbox before delivery. Executable files and macro-enabled documents from outside should be blocked.
- URL rewriting and checking at the time of click should be enabled so that links that become harmful later are blocked.
- A warning banner should be added to emails that come from outside the organisation.

- Multi-factor authentication should be required for email, VPN and important applications, so that a stolen password alone is not enough. Phishing-resistant methods such as FIDO2 keys are better.
- Endpoint Detection and Response (EDR) and antivirus should be used to stop malware, and web and DNS filtering should block known phishing websites.
- Logs should be sent to a SIEM so that unusual logins, wrong-location logins and sudden mailbox rules can be detected.

2.6 Organisational Policies

Clear policies are needed so that every employee knows what to do. The organisation should have an Information Security Policy and an Acceptable Use Policy which explain how email, internet and company accounts should be used. An email handling policy should state that passwords are never shared by email and that suspicious messages must be reported at once. A password policy should require long and unique passwords and mandatory MFA. For payments or change of bank details, a verification procedure should be followed, such as calling the person on a known number, which prevents business email compromise.

An Incident Response Plan should explain how a phishing incident is reported, contained and investigated, including password reset, session removal and isolation of the infected computer, as given in NIST SP 800-61. Access should follow the principle of least privilege so that one stolen account cannot reach all the systems. A non-punishment reporting policy is also important, because employees who are not afraid of blame will report mistakes quickly. Finally, the results of training and simulations should be reviewed regularly by the management.

2.7 Implementation and Measuring Success

In the first 30 days the organisation should enable MFA, reset the passwords of the users who entered credentials, add the reporting button and train the users who clicked. In the next 60 to 90 days it should conduct company-wide training, tune the email gateway, enable DMARC enforcement and publish the updated policies. After that, a second simulation should be done with different themes, and the incident response plan should be tested.

The success can be measured with a lower click rate (target below 10% in one year), a lower credential submission rate (below 3%), a higher reporting rate (above 60%), faster reporting time and a high training completion rate. The reporting rate is very important because it shows that the employees have become an active part of the defence.

2.8 Conclusion

The GoPhish report proves that many employees can be easily fooled by a phishing email, and that a good number of them gave their passwords and downloaded a suspicious file. The weaknesses are low awareness, risky habits, and gaps in technical controls and policies. By giving continuous training, using layered email security and MFA, and having clear policies, the organisation can make its employees a human firewall and reduce the success of social engineering attacks.

Question 3: DNS Zone Transfer (AXFR) Analysis (10 Marks)

3.1 Introduction

The Domain Name System (DNS) converts domain names into IP addresses and also stores other information such as mail servers. All the records of a domain are kept in a zone on the primary (master) name server. For backup, the secondary (slave) servers copy this zone from the primary using a zone transfer, and the full copy is called AXFR. This is a normal feature, but it must be allowed only for the authorised secondary servers.

In this question the Dig tool shows that the DNS server of the organisation allows a successful zone transfer (for example by the command dig axfr domain @nameserver), so the internal hostnames, mail servers and other DNS records were given to an unauthorised person.

3.2 Analysis of the Report

Record	Example	Information exposed
A / AAAA	intranet, db01, vpn	Hostnames and IP addresses of servers, including internal systems
MX	mail.example.com	The mail servers of the organisation
NS	ns1, ns2	The authoritative DNS servers
CNAME	webmail, portal, staging	Aliases of applications and external services
TXT	SPF and verification records	Email policy and third-party services in use
SRV	_ldap._tcp, _kerberos._tcp	Location of directory and authentication services

The report shows that the DNS server does not check who is asking for the zone. By one single query, a person without any password can get a full list of the organisation's hosts, which would otherwise need thousands of guesses and lookups. It is like giving the full map of the company network to a stranger.

A zone transfer is needed in a normal network because the secondary server must have the same records as the primary server. Because of this, the DNS software supports it by default, and many administrators forget to restrict it. This is the reason why the misconfiguration is still found in many assessments, even though it is a very old issue. In an ethical hacking engagement, testing for AXFR is one of the first steps of DNS footprinting, and a successful transfer is always reported as a finding.

3.3 Security Implications of the Exposed Information

The first implication is that the structure of the internal network is revealed. Names like db01, vpn, admin, backup or jenkins tell the attacker which servers are important. Test, staging and old servers are also listed, and these are usually not well patched or protected. The mail server and TXT records help in planning phishing and email spoofing. The zone transfer is also quiet and quick, so the attacker saves a lot of time and the chance of being detected is less than in brute-force guessing of subdomain names. In short, it breaks the confidentiality of internal information, which should never be public.

3.4 How Attackers Could Exploit the Findings

- Targeted scanning: the attacker scans only the discovered IP addresses and services, so the attack is faster and more focused.
- Attacking weak hosts: development, test or old servers may be the easy entry point, and from there the attacker moves to the production systems.
- Phishing and social engineering: real hostnames and mail servers help to create convincing fake emails and login pages.
- Subdomain takeover: if a record points to a cloud service which is no longer used, the attacker can take it and host a harmful website under the company's own domain.
- Email spoofing and DNS attacks: information about mail records and name servers supports spoofing, cache poisoning and denial of service attempts.
- Lateral movement: after entering the network, the attacker already knows the names of the directory, file and database servers.

3.5 Best Practices to Secure the DNS Infrastructure

- Restrict zone transfers to the IP addresses of the authorised secondary servers only. For example, in BIND this is done with allow-transfer { 203.0.113.10; }; and all others are denied. If there is no secondary server, transfers should be disabled completely.
- Use TSIG (Transaction Signature) keys so that only the servers that have the shared key can get the zone.
- Allow TCP port 53 only between the DNS servers, and block it from the internet.
- Use split-horizon DNS, which means separate internal and external DNS views. Internal names must never be present in the public zone.
- Keep the records minimum. Avoid names that reveal the function of a server and delete unused records and old CNAMEs to stop subdomain takeover.

- Enable DNSSEC to protect the DNS answers from spoofing and cache poisoning.
- Update the DNS software, run it with least privilege, disable recursion on authoritative servers and hide the version.
- Use rate limiting and more than one name server in different locations for availability.
- Log and monitor zone transfer requests and unusual queries, and send them to the SIEM.
- Test again with Dig after every change to confirm that the transfer is refused for unauthorised hosts.

The administrator should also test the DNS server from outside the network after the changes. When an unauthorised host asks for a zone transfer, the server must refuse the request, and the refusal should be recorded in the logs. A regular review of the DNS configuration, at least once in a few months or after every major change, helps to find such mistakes early.

3.6 Conclusion

An open DNS zone transfer gives the attacker a complete list of the hosts, mail servers and services without any authentication. It does not break a system directly, but it makes every next stage of an attack much easier. Restricting AXFR to authorised servers, using TSIG, separating internal and external DNS, cleaning the records and using DNSSEC and monitoring will remove this weakness and make the DNS infrastructure more secure.

Overall Conclusion

The three reports in this assessment show different parts of footprinting and information gathering: scanning of services with Nmap, social engineering with GoPhish and DNS enumeration with Dig. The common lessons are that unnecessary open services and exposed information increase the risk, that people are an important layer of security, and that simple misconfigurations are often easier for attackers than complex vulnerabilities.

An organisation that keeps its systems updated, exposes only what is needed, uses strong authentication, trains its employees, secures its DNS and monitors continuously can greatly reduce its risk. Ethical hacking, done with proper permission, helps to find these weaknesses and correct them before a real attacker uses them.

References

1. NIST Special Publication 800-115, Technical Guide to Information Security Testing and Assessment.
2. NIST Special Publication 800-81-2, Secure Domain Name System (DNS) Deployment Guide.
3. NIST Special Publication 800-61, Computer Security Incident Handling Guide.
4. Nmap Reference Guide, https://nmap.org.
5. GoPhish Documentation, https://getgophish.com.
6. OWASP Top 10 Web Application Security Risks, https://owasp.org.
7. MITRE ATT&CK Framework, https://attack.mitre.org.
8. CIS Critical Security Controls and CIS Benchmarks, Center for Internet Security.
9. RFC 5936, DNS Zone Transfer Protocol (AXFR), IETF.
10. RFC 8945, Secret Key Transaction Authentication for DNS (TSIG), IETF.
11. RFC 7489, Domain-based Message Authentication, Reporting and Conformance (DMARC), IETF.